

AWS SAP-C02

FINAL HANDWRITTEN-STYLE EXAM CHEAT SHEET

Solutions Architect - Professional | Recall Rules • Traps • Architect Decisions

Built from our 75-question professional mock + expanded exam-perspective revision notes.

How to use this PDF

- First pass: read only green arrow rules and red trap notes.
- Second pass: cover the answer mentally and recall the AWS service from the clue.
- Final 2-3 days: focus heavily on the “Your Weak Areas” section near the end.
- In the exam, satisfy every requirement first; optimize cost/operations only after that.

⚠ Professional-level questions often contain 2 technically possible answers. Pick the one that meets ALL constraints with least operational overhead and correct security boundaries.

1. GOLDEN EXAM RULES

- Read the LAST sentence first: what exactly is being asked - BEST, MOST secure, LEAST cost, MINIMUM ops, TWO/THREE?
 - MOST secure → least privilege + private access + temporary credentials + encryption + centralized guardrails.
 - LEAST operational overhead → native managed/serverless service normally beats custom EC2/scripts.
 - MOST cost-effective → first satisfy availability/RPO/RTO/security, then optimize cost.
 - Highly available → usually Multi-AZ. Disaster recovery → usually cross-Region.
 - Many AWS accounts → think Organizations, delegated admin, StackSets, SCP, RAM.
 - Prevent action even for AdministratorAccess → SCP explicit Deny.
 - Temporary access → IAM role + STS; avoid IAM users/access keys where roles work.
- ⚠ "Can work" is not the same as "BEST answer".

Fast elimination checklist

- Does it meet every stated requirement?
- Does it require an application rewrite when the question says minimal/no changes?
- Is there a managed AWS service that replaces custom infrastructure?
- Does it introduce public internet when private connectivity is required?
- Does it create broad permissions when the question says least privilege?

2. IAM + ORGANIZATIONS CORE

IAM / SCP / Boundary

- Identity policy → what this user/role can do.
 - Resource policy → who can access this resource.
 - Permissions boundary → maximum permissions for an IAM principal.
 - SCP → maximum permission guardrail for accounts/OUs; SCP does NOT grant permissions.
- ⚠ Explicit Deny wins. AdministratorAccess cannot override an SCP Deny.
- Current + future accounts in an OU need same restriction → attach SCP/policy at OU level.

Cross-account AssumeRole

- Target account role trust policy must trust source principal/account.
- Source identity must have sts:AssumeRole permission.
- STS gives temporary credentials - preferred over long-term access keys.

External ID

- Third-party SaaS assuming customer roles → External ID → protects against confused deputy problem.

Role chaining

- User/federation → Role can use target role MaxSessionDuration (up to configured limit).
 - Role → AssumeRole → another Role = role chaining → second role session max 1 hour.
- ⚠ A target role configured for 12 hours does NOT remove the 1-hour chaining limit.

3. CROSS-ACCOUNT KMS - HIGH PRIORITY

- Encrypted cross-account resource = TWO permission layers: resource access + KMS key access.
- S3 SSE-KMS cross-account → S3 GetObject permission + KMS Decrypt permission.
- Encrypted EBS snapshot sharing → snapshot share permission + customer-managed KMS key permission.
- Cross-account S3 replication with KMS → replication rule + IAM replication role + source/destination KMS permissions + destination key configuration.

⚠ AWS-managed KMS keys are a common trap for cross-account sharing scenarios; customer-managed keys give policy control.

4. MULTI-ACCOUNT SECURITY OPERATING MODEL

- GuardDuty across Organizations → delegated administrator + auto-enrollment.
- Security Hub organization-wide → delegated administrator + central finding aggregation.
- CloudTrail organization trail → central Log Archive account/S3 bucket.
- New accounts automatically receive resources → CloudFormation StackSets service-managed permissions targeting OUs.
- Central networking account owns VPC/subnets, app accounts deploy resources there → VPC Sharing + AWS RAM.

5. NETWORKING DECISION MAP

- Two VPCs, simple direct private connectivity → VPC Peering.
- Many VPCs / hub-and-spoke / centralized routing → Transit Gateway.
- Expose one private service to many VPCs/accounts → PrivateLink.
- Share actual subnets across accounts → VPC Sharing + RAM.
- Dedicated on-prem ↔ AWS private circuit → Direct Connect.
- Encrypted tunnel over internet → Site-to-Site VPN.

PrivateLink

- Provider: NLB → Endpoint Service. Consumer: Interface Endpoint.
- Great when CIDRs overlap and consumers must access only one service, not entire provider VPC.
- Friendly private hostname instead of vpce-* DNS → endpoint service private DNS + verification + private DNS enabled.

Transit Gateway + inspection

- TGW route tables control segmentation/propagation: Prod and Dev can be isolated while both reach Shared Services.
- Stateful firewall + asymmetric return path → enable TGW appliance mode on inspection VPC attachment.

Gateway vs Interface endpoints

- S3/DynamoDB Gateway Endpoint → route-table based, no security group, endpoint policy, low/no endpoint hourly cost.
- Interface Endpoint → PrivateLink ENIs/private IPs, security groups, endpoint policy, hourly/data cost.
- Prevent S3 exfiltration through gateway endpoint → restrictive endpoint policy + bucket/resource policies.

⚠ Gateway endpoints do NOT use security groups.

6. HYBRID DNS

- AWS → on-prem DNS = Route 53 Resolver OUTBOUND endpoint + forwarding rules.
- On-prem → AWS private hosted zones = Resolver INBOUND endpoint.
- Many accounts/VPCs → centralize Resolver endpoints/rules and share rules with RAM.

7. DIRECT CONNECT

- Multiple VIFs on one physical DX connection ≠ physical redundancy.
- Two connections at same DX location → protects device/connection failure, not site failure.
- Highest resilience → redundant DX connections on separate devices at separate DX locations + BGP.
- ⚠ If question says survive entire DX location failure, same-location redundancy is insufficient.

8. ROUTE 53 POLICIES

- Primary/secondary → Failover.
- Traffic percentages/canary → Weighted.
- Lowest network latency → Latency-based.
- User geographic location/country → Geolocation.
- Resource geographic position + bias → Geoproximity.
- Return multiple healthy records → Multi-value answer.

9. GLOBAL ACCELERATOR vs CLOUDFRONT

- Global Accelerator → static anycast IPs, TCP/UDP, AWS global backbone, fast endpoint failover, no DNS-cache dependency.
- CloudFront → HTTP/HTTPS CDN, edge caching, content acceleration, signed URLs/cookies, origin failover.
- ⚠ Fixed global IPs + TCP + no DNS failover dependency → Global Accelerator, not CloudFront.

10. S3 STORAGE + DATA PROTECTION

Storage classes

- Frequent access → S3 Standard.
- Unknown/changing access → Intelligent-Tiering.
- Infrequent, millisecond retrieval → Standard-IA.
- Single-AZ acceptable → One Zone-IA.
- Archive with immediate-ish access → Glacier Instant Retrieval.
- Archive with minutes/hours retrieval → Glacier Flexible Retrieval.
- Longest-term cheapest archive → Glacier Deep Archive.

Object Lock

- Governance mode → privileged principal with bypass permission CAN bypass retention.
- Compliance mode → protected version cannot be deleted / retention cannot be shortened during retention period.
- WORM / regulator / even admin cannot delete → Object Lock Compliance mode.
- Retention + cheaper tiers + eventual deletion → Object Lock + Lifecycle policy.

Replication

- New objects → S3 Replication (CRR/SRR depending Regions).
- Existing objects → S3 Batch Replication.
- New + existing → replication rule + Batch Replication.
- Cross-account destination ownership required → configure replica ownership / Object Ownership appropriately.

Multi-Region Access Point

- Multiple regional S3 buckets + one global S3 endpoint + automatic routing → S3 Multi-Region Access Point.
- ⚠ Transfer Acceleration accelerates transfers to a bucket; it does not create one global multi-bucket access endpoint.

11. CLOUDFRONT + PRIVATE S3

- Private S3 origin → CloudFront Origin Access Control (OAC) + bucket policy; keep Block Public Access on.
- Temporary paid/private access → signed URL or signed cookie.
- One/few objects → signed URL. Multiple restricted objects/path → signed cookies may fit better.
- Primary/secondary origins with HTTP failure status codes → CloudFront Origin Group.

12. EFS / FSx / STORAGE GATEWAY

- Linux shared NFS → EFS.
- Windows SMB + AD + Windows ACLs → FSx for Windows File Server.
- HPC/high-performance parallel filesystem → FSx for Lustre.
- NetApp enterprise features → FSx for ONTAP.
- OpenZFS semantics/features → FSx for OpenZFS.
- On-prem app must keep SMB/NFS while authoritative data is in S3 + local cache → Storage Gateway File Gateway.
- Block/iSCSI hybrid storage → Volume Gateway. Virtual tape workflows → Tape Gateway.

13. DATASYNC + SNOW FAMILY

- DataSync → automated online bulk/incremental file data transfer: NFS/SMB/S3/EFS/FSx patterns.
- ⚠ DataSync does NOT convert Oracle/SQL Server databases to PostgreSQL/Aurora.
- Huge initial dataset + bandwidth constrained → Snowball Edge / Snow Family for offline seeding.
- After bulk seed, recurring daily increments → DataSync.

14. RDS / AURORA DECISION RULES

- RDS Multi-AZ → high availability / failover.
- Read Replica → read scaling/reporting.
- ⚠ Traditional RDS Multi-AZ standby is not your reporting endpoint.
- Cross-Region read replica → DR copy/read capability + promotion option.

Aurora Global Database

- Low-latency cross-Region replication, seconds-level RPO, fast secondary promotion → Aurora Global Database.

→ Secondary Region serves local reads. Eligible occasional writes can use Global Database write forwarding to primary.

⚠ RDS Proxy does NOT make a secondary Aurora cluster writable.

RDS Proxy

→ Lambda + RDS/Aurora + connection storm/exhaustion → RDS Proxy.

→ RDS Proxy → connection pooling/reuse, improved connection management; credentials commonly via Secrets Manager.

Aurora Serverless v2

→ Relational + highly variable demand + automatic granular scaling + low ops → Aurora Serverless v2.

15. DYNAMODB

→ Massive scale + low-latency key-value/document + serverless → DynamoDB.

→ Multi-Region multi-active reads/writes → DynamoDB Global Tables.

→ Few partition keys generate huge traffic → hot partition → improve key cardinality / write sharding.

→ Write sharding example: customer#0, customer#1, customer#2; query all shards when reading customer history.

⚠ Adding a GSI with the SAME hot partition key does not solve skew.

16. MIGRATION + MODERNIZATION TOOL MAP

→ Server/VM rehost → AWS Application Migration Service (MGN).

→ Database data migration + CDC → AWS DMS.

→ Heterogeneous DB schema/code conversion → DMS Schema Conversion / AWS SCT.

→ File transfer/sync → DataSync.

→ PB-scale offline transfer → Snow Family.

→ Discover servers/utilization/dependencies → Application Discovery Service / migration discovery tooling.

→ Track migrations centrally → Migration Hub.

Heterogeneous DB pattern

→ Oracle/SQL Server → Aurora PostgreSQL = schema/code conversion + DMS full load + CDC.

→ Full load moves baseline. CDC keeps target nearly synchronized until cutover.

⚠ MGN replicates servers; it does not transform Oracle into PostgreSQL.

⚠ Native SQL Server backup cannot be restored directly into Aurora PostgreSQL.

17. DISASTER RECOVERY STRATEGIES

→ Backup & Restore → cheapest, highest RPO/RTO.

→ Pilot Light → core critical services/data running; scale/build rest during disaster.

→ Warm Standby → functional reduced-capacity environment already running; scale up during disaster.

→ Multi-Site / Active-Active → both Regions serving, highest cost, lowest RPO/RTO.

→ Secondary app stack exists but reduced + global DB + scale on failover → Warm Standby.

18. SQS / SNS / EVENTBRIDGE / KINESIS

→ SQS → queue, buffering, decoupling, async work.

- SNS → push pub/sub fan-out.
- EventBridge → event routing/filtering/integration across producers/consumers/accounts.
- Kinesis Data Streams → high-throughput ordered streaming per partition key + replay + multiple consumers.

SQS Standard vs FIFO

- Standard → very high throughput, at-least-once delivery, best-effort ordering.
- FIFO → ordering + MessageGroupId + deduplication features.
- Same MessageGroupId = ordered serial flow. Different groups = parallelism.

Lambda + SQS

- One malformed message makes whole batch retry → enable partial batch responses and return failed message identifiers.
- Repeated poison message → SQS DLQ + appropriate maxReceiveCount.

Idempotency - exam favorite

- Exactly-once BUSINESS effect → application-level idempotency using unique transaction/request ID + durable check.

⚠ FIFO/deduplication does not replace idempotent payment/order logic.

19. STEP FUNCTIONS

- Multi-step workflow + state + retry + catch + branching + compensation → Step Functions.
- Payment succeeded but inventory failed → Catch → compensation/refund step.
- EventBridge routes events; SQS buffers; Step Functions orchestrates workflow.

20. AUTO SCALING + SPOT

- SQS worker scaling → custom metric "backlog per worker" $\approx$ queue depth / active workers; use target tracking.
- Spot best for stateless, retryable, checkpointed, fault-tolerant workloads.
- Resilient Spot → multiple instance types + multiple AZs + price-capacity-optimized allocation strategy.
- ⚠ One instance type + one AZ = narrow Spot pool and more interruption risk.

21. ALB vs NLB

- ALB → Layer 7 HTTP/HTTPS, host/path routing, WebSocket/gRPC use cases.
- NLB → Layer 4 TCP/UDP/TLS, extreme performance, static IP support, PrivateLink provider backend.
- Path/host based routing → ALB. PrivateLink endpoint service → NLB.

22. SECURITY SERVICE MAP

- GuardDuty → threat detection.
- Security Hub → central security findings/posture aggregation.
- Inspector → vulnerability management for supported workloads/images/functions.
- Macie → sensitive data discovery in S3.
- CloudTrail → who did what AWS API action.
- CloudWatch → metrics, logs, alarms, observability.
- AWS Config → configuration state/history/compliance.

- Secrets Manager → secrets + automatic rotation use cases.
- Systems Manager Parameter Store → configuration/parameters and simpler secret storage use cases.

23. EKS / WORKLOAD IDENTITY

- Specific Kubernetes service account needs AWS permissions → pod/service-account IAM identity such as IRSA; do not give whole worker-node role broad access.
- Cross-account S3 from EKS → scoped pod identity/role + target bucket/KMS permissions as needed.

24. DATA LAKE GOVERNANCE

- S3 stores data. Glue Data Catalog stores metadata. Athena queries. Lake Formation governs permissions.
- Cross-account centralized data lake + table/column permissions → Lake Formation.

25. CLOUDFORMATION STACKSETS

- Same IAM/Config/CloudWatch resources across 200 accounts and Regions → StackSets.
- Organizations integration + service-managed permissions + OU targets → automatic deployment to new accounts.

26. COST OPTIMIZATION CLUES

- Steady predictable compute → Savings Plans / Reserved pricing approaches.
 - Interruptible fault-tolerant compute → Spot.
 - Unknown S3 access pattern → Intelligent-Tiering.
 - Archive → Glacier families based on retrieval requirement.
 - Variable event-driven compute → Lambda/serverless.
 - Variable relational database → Aurora Serverless v2.
- ⚠ Do not pick cheapest option if it violates RPO/RTO/security/latency requirements.

27. YOUR MOCK #1 WEAK AREAS - MEMORIZE

Cross-account KMS

- Resource permission + KMS permission. Think two doors.

Migration service selection

- MGN=server; DMS=data; Schema Conversion/SCT=schema+code; DataSync=files.

Global routing

- Fixed IP + TCP/UDP + no DNS dependency → Global Accelerator.
- One global S3 endpoint across regional buckets → Multi-Region Access Point.

S3 retention

- Even privileged admin cannot delete during retention → Object Lock Compliance.

DynamoDB

- Hot key/partition → write sharding / better partition key.

IAM

- Role → Role = max 1 hour chaining session.

Exactly-once business effect

→ Idempotency required; messaging guarantees alone are not enough.

Aurora

→ Secondary local reads + occasional writes → write forwarding; RDS Proxy is only connection management.

28. "SEE THIS → THINK THIS" FINAL RECALL

Admin must be blocked → SCP explicit Deny

Third-party AssumeRole → External ID

Cross-account encrypted → Resource permission + KMS permission

Role assumes role → 1-hour chaining

Many VPCs → Transit Gateway

One private service → PrivateLink

Share subnet → RAM / VPC Sharing

TGW + stateful firewall → Appliance Mode

Fixed global IP → Global Accelerator

Global web cache → CloudFront

Private S3 via CloudFront → OAC

S3 immutable → Object Lock Compliance

Existing S3 replication → Batch Replication

Global S3 endpoint → Multi-Region Access Point

Windows SMB → FSx Windows

Linux NFS → EFS

Hybrid SMB/NFS + S3 → File Gateway

Lambda DB connection storm → RDS Proxy

Aurora cross-Region → Global Database

Aurora secondary writes → Write Forwarding

RDS HA → Multi-AZ

RDS reads → Read Replica

DynamoDB global writes → Global Tables

DynamoDB hot partition → Write Sharding

VM rehost → MGN

DB data migration → DMS

DB schema conversion → SCT / DMS Schema Conversion

File migration → DataSync

Huge offline data → Snowball

Discover dependencies → Application Discovery

Ordered stream + replay → Kinesis

Queue → SQS

Fan-out → SNS

Event routing → EventBridge

Workflow → Step Functions

Poison messages → DLQ

Bad message in Lambda/SQS batch → Partial Batch Response

Duplicate payment → Idempotency

Specific EKS workload IAM → IRSA / pod identity

Multi-account deployment → StackSets

Data lake fine-grained permissions → Lake Formation

Threat detection → GuardDuty

Central findings → Security Hub

API audit → CloudTrail

Config compliance → AWS Config

29. LAST-MINUTE EXAM METHOD

- Step 1: Identify hard requirements (RPO/RTO, protocol, public/private, cross-account, Region/AZ, latency, cost).
- Step 2: Eliminate any answer violating even one hard requirement.
- Step 3: Among remaining answers, prefer AWS-managed/native integration and least operational overhead.
- Step 4: For security questions, prefer temporary credentials, least privilege, resource + key permissions, organization guardrails.
- Step 5: For “MOST cost-effective”, choose the cheapest architecture that still meets every technical requirement.
- Step 6: Never leave an answer blank; there is no benefit to not guessing when time expires.

⚠ Watch the words BEST, MOST, LEAST, MINIMUM, TWO, THREE. Missing the qualifier can lose an easy mark.

30. FINAL MEMORY MANTRA

“Meet ALL requirements first. Then choose the most AWS-native, least operational, least-privilege design.”

Mock #1 result: $63/75 = 84\%$. Your fundamentals are strong; turn the weak-area patterns into instant recall.